NEXGENIUS CONCIERGE LIMITED

DATA PROTECTION POLICY

Approved by: Executive Director

TABLE OF CONTENTS

1. Introduction and Purpose 1
2. Scope 1
3. Legal and Regulatory Framework 2
4. Definitions 2
5. Data Protection Principles 3
6. Roles and Responsibilities 3
6.1 Board of Directors and Senior Management 3
6.2 Data Protection Officer (DPO) 3
6.3 Employees and Contractors 4
6.4 Developer and Vendors 4
7. Lawful Basis for Processing 4
8. Categories of Data Subjects and Personal Data Processed 4
9. Sensitive Personal Data 5
10. Children's Data 5
11. Data Protection by Design and Default 6
12. Consent Management 6
13. Data Subject Rights 7
14. Developer, Vendors and Sub-Processors 7
15. Cross-Border Data Transfers 8
16. Data Security Measures 8
17. Personal Data Breach Management 9
18. Data Protection Impact Assessments 9
19. Data Retention and Disposal 9
20. Registration with the Office of the Data Protection Commissioner 10
21. Training and Awareness 10
22. Complaints Handling 10
23. Monitoring, Audit and Compliance 10
24. Policy Violations and Disciplinary Action 11
25. Policy Review 11
Annex A. Data Protection Officer Contact Details 12
Annex B. Illustrative Data Retention Schedule 12
Annex C. Personal Data Breach Reporting Procedure 12
Annex D. Register of Processing Activities — Template Fields 13

1. Introduction and Purpose

NexGenius Concierge Limited ("NexGenius", the "Company", "we", "us" or "our") owns and operates the NexGenius Platform, a technology marketplace connecting End-Users, independent Riders, Merchants and participating hotels and other Property Partners to enable ordering, delivery and in-property concierge fulfilment. In the course of providing this service, NexGenius collects, stores, transmits and otherwise processes personal data belonging to End-Users, Riders, Merchants, Property Partners, employees, contractors and other individuals.

This Policy sets out how NexGenius identifies, collects, uses, stores, shares, retains, secures and disposes of personal data in compliance with the Data Protection Act, 2019 (the "Act") and the Regulations made under it, including the Data Protection (General) Regulations, 2021, the Data Protection (Registration of Data Controllers and Data Processors) Regulations, 2021, and the Data Protection (Complaints Handling and Enforcement Procedures) Regulations, 2021 (together, the "Regulations").

The Policy also operationalises the data protection and security commitments undertaken by NexGenius under (a) the Software Development Agreement governing the design, development and deployment of the NexGenius Platform, and (b) the Company's standard-form Data Processing Agreement entered into with vendors, merchants and other counterparties who process personal data on the Company's behalf or who receive personal data from the Platform.

The purpose of this Policy is to:

- ensure that NexGenius processes personal data lawfully, fairly and transparently;
- embed "Data Protection by Design and Default" into every system, feature and vendor relationship, consistent with the warranty given by the Company's software developer;
- protect the rights of data subjects, including End-Users, Riders, Merchants, Property Partners and their guests;
- set out the roles and responsibilities of the Board, the Data Protection Officer, management and staff; and
- reduce the Company's regulatory, financial, reputational and operational risk.

2. Scope

This Policy applies to:

- all personal data processed by NexGenius in any format (electronic, paper or verbal), including data processed through the NexGenius Platform's End-User

app, Rider app, Merchant portal, Property Partner integrations and Admin Portal/Web CMS;

- all directors, employees, interns and contractors of NexGenius;
- all third parties who process personal data on the Company's behalf or who receive personal data from the Company, including the Company's software developer(s), vendors, Merchants, Property Partners, payment service providers and mobile money operators, each to the extent set out in a signed Data Processing Agreement or equivalent contractual instrument; and
- all categories of personal data processed by or through the Platform, including identity and contact data, location and trip-tracking data, order and transaction data, payment tokens, and any sensitive personal data or children's data encountered in the course of the Company's business.

3. Legal and Regulatory Framework

This Policy is issued under, and must be read together with, the following:

- the Data Protection Act, 2019 (Kenya), and the Regulations made under it;
- Article 31 of the Constitution of Kenya, 2010, which guarantees the right to privacy;
- guidance, codes of conduct and directions issued from time to time by the Office of the Data Protection Commissioner ("ODPC");
- applicable sector-specific requirements, including those of the Central Bank of Kenya and licensed Payment Service Providers and mobile money operators in respect of payment token and financial data handling; and
- the data protection and security clauses of the Company's Software Development Agreement and its standard-form Data Processing Agreement, which this Policy is designed to give internal effect to.

In the event of any conflict between this Policy and the Act, the Act shall prevail.

4. Definitions

Unless the context requires otherwise, terms used in this Policy, including "personal data", "processing", "data controller", "data processor", "data subject", "personal data breach", "sensitive personal data", "consent" and "data protection officer", bear the meanings given to them in the Act. In this Policy:

- "Platform" means the NexGenius Platform (mobile applications, Admin Portal/Web CMS and associated infrastructure);
- "End-User", "Rider", "Merchant" and "Property Partner" bear the meanings ascribed to them in the Company's Software Requirement Specifications and commercial agreements;

- "Developer" means any contracted software developer engaged to design, develop, test, deploy or maintain the Platform under a Software Development Agreement with the Company;
- "Vendor" means any third party, including a Merchant, Property Partner or service provider, that processes personal data on the Company's behalf, or from whom the Company processes personal data, under a Data Processing Agreement; and
- "ODPC" means the Office of the Data Protection Commissioner established under the Act.

5. Data Protection Principles

In accordance with section 25 of the Act, every NexGenius employee, contractor and Vendor involved in processing personal data on the Company's behalf must ensure that personal data is:

- processed lawfully, fairly and in a transparent manner in relation to the data subject;
- collected for explicit, specified and legitimate purposes, and not further processed in a manner incompatible with those purposes;
- adequate, relevant, and limited to what is necessary in relation to the purposes for which it is processed;
- collected only where a valid explanation is provided whenever information relating to family or private affairs is required;
- accurate and, where necessary, kept up to date, with reasonable steps taken to erase or rectify inaccurate data without delay;
- kept in a form which identifies the data subject for no longer than is necessary for the purposes for which it was collected; and
- not transferred outside Kenya, unless there is proof of adequate data protection safeguards or consent from the data subject, in accordance with sections 48 to 50 of the Act.

6. Roles and Responsibilities

6.1 Board of Directors and Senior Management

The Board has ultimate accountability for data protection compliance and shall approve this Policy, allocate adequate resources to data protection compliance, and receive periodic reports from the Data Protection Officer.

6.2 Data Protection Officer (DPO)

In accordance with section 24 of the Act, having regard to the fact that the Company's core activities involve regular and systematic monitoring of data subjects

at scale (including Rider geolocation tracking and End-User order history) and the processing of payment-related data, NexGenius shall designate a Data Protection Officer. The DPO shall:

- monitor internal compliance with the Act, the Regulations and this Policy;
- advise on data protection impact assessments and monitor their performance under section 31 of the Act;
- act as the contact point for the ODPC and for data subjects on all processing issues;
- maintain the Company's registration under section 18 of the Act and notify the ODPC of any change in registration particulars under section 19(2);
- coordinate the Company's response to personal data breaches, data subject requests and complaints; and
- maintain the Company's Register of Processing Activities and its inventory of Data Processing Agreements with Vendors and the Developer.

6.3 Employees and Contractors

All employees and contractors who process personal data in the course of their duties must complete data protection training, follow this Policy and any related procedures, and report any actual or suspected personal data breach to the DPO immediately, and in any event within twenty-four (24) hours of becoming aware of it.

6.4 Developer and Vendors

Any Developer engaged to build or maintain the Platform, and any Vendor, Merchant, Property Partner or service provider who processes personal data on the Company's behalf, shall be bound by a written Data Processing Agreement in the Company's standard form (or equivalent contractual data protection clauses) and shall comply with the obligations summarised at section 14 of this Policy.

7. Lawful Basis for Processing

NexGenius shall only process personal data where at least one lawful basis applies, namely: the data subject has given consent; processing is necessary for the performance of a contract with the data subject (for example, fulfilment of an order placed on the Platform); processing is necessary for compliance with a legal obligation; processing is necessary to protect the vital interests of the data subject; or processing is necessary for the legitimate interests of the Company or a third party, provided such interests are not overridden by the interests, rights or freedoms of the data subject. The specific lawful basis relied upon for each processing activity shall be recorded in the Company's Register of Processing Activities (Annex D).

8. Categories of Data Subjects and Personal Data Processed

The table below summarises the main categories of data subjects and personal data processed through the Platform. The full and current inventory is maintained in the Register of Processing Activities.

Data Subject	Typical Personal Data	Primary Purpose
End-User	Name, contact details, delivery address, order history, in-app location data, payment tokens	Order placement, delivery/concierge fulfilment, payment processing
Rider	Name, contact details, national ID, real-time geolocation and trip-tracking data, bank/mobile money details	Order routing and dispatch, trip tracking, commission settlement
Merchant	Business registration details, contact person data, banking/mobile money details, transaction and commission data	Order fulfilment, commission settlement, reporting
Property Partner / Guest	Property and contact person data; guest name, room and stay data shared for concierge fulfilment	In-property concierge fulfilment
Employee / Contractor / Developer	Name, contact and identification details, employment/contract records, system access logs	Employment/engagement administration, system security

9. Sensitive Personal Data

Sensitive personal data, being data revealing race, health status, ethnic social origin, conscience, belief, genetic data, biometric data, property details, marital status, family details, or sex or sexual orientation, shall only be processed by NexGenius or its Vendors on a ground permitted under Part V (sections 44 to 47) of the Act. Examples relevant to the Platform include health data collected by Pharmacy or health-related Merchants, and biometric data used, where applicable, for Rider identity verification. Additional technical and organisational safeguards, including restricted access, field-level encryption or masking, and, in respect of health data, processing only by or under the responsibility of a person subject to an obligation of professional secrecy, shall apply to any sensitive personal data, consistent with section 46 of the Act.

10. Children's Data

NexGenius shall not knowingly process personal data relating to a child otherwise than in accordance with section 33 of the Act, and only where consent has been given by the child's parent or guardian, having regard to the factors listed in section 33(3) of the Act. Where the Platform's registration flows or Merchant integrations may capture data belonging to a child (for example, an order placed for or by a minor, or a guest

profile at a Property Partner), age-verification and parental/guardian consent mechanisms shall be implemented, and such data shall be processed in a manner that protects and advances the best interests of the child.

11. Data Protection by Design and Default

Consistent with the warranty given by the Company's Developer under the Software Development Agreement, the Platform shall be designed, developed and maintained in strict compliance with the Act, implementing Data Protection by Design and Default. This includes, at minimum:

- collecting only the personal data reasonably necessary for the specific feature or service (data minimisation) and defaulting new features to the most privacy-protective settings;
- encryption of personal data in transit and at rest;
- role-based access control (RBAC) on the Admin Portal/Web CMS, restricting access to personal data to personnel who require it to perform their role;
- secure handling of payment tokens in compliance with the applicable Payment Service Provider's and mobile money operator's (M-Pesa, Airtel Money) API and security standards, so that NexGenius and its Developer do not store raw card or mobile money credentials beyond what is permitted;
- secure authentication, and logging and audit trails for access to systems containing personal data;
- regular vulnerability assessment and penetration testing (VAPT) and timely security patching before and after Go-Live; and
- a documented, mandatory Data Protection Impact Assessment (see section 18) before any new feature, integration or Merchant category that is likely to involve high-risk processing (for example, a new sensitive-data-handling Merchant vertical) goes live.

The Developer is strictly prohibited from accessing, mining or otherwise using End-User, Rider, Merchant or Property Partner data for its own purposes, and, to the extent it processes such data during development and testing, is bound by the terms of the Company's Data Processing Agreement.

12. Consent Management

Where consent is relied upon as the lawful basis for processing, NexGenius shall ensure that consent is free, specific, informed and unambiguous, capable of being withdrawn as easily as it was given, and recorded (including the version of the relevant privacy notice or terms presented to the data subject at the time). Pre-ticked boxes, bundled consent and default opt-ins shall not be used to evidence valid consent.

13. Data Subject Rights

In accordance with section 26 and related provisions of the Act, End-Users, Riders, Merchants, Property Partners and other data subjects have the right to:

- be informed of the use to which their personal data is to be put;
- access their personal data in the custody of NexGenius;
- object to the processing of all or part of their personal data;
- request correction or deletion of false or misleading data about them;
- request restriction of processing under section 34 of the Act;
- object to a decision based solely on automated processing, including profiling, which produces legal effects concerning or significantly affects them, under section 35 of the Act; and
- receive their personal data in a structured, commonly used and machine-readable format, and have it transmitted to another controller (data portability), under section 38 of the Act.

NexGenius shall respond to data subject requests without undue delay and, in respect of data portability requests, within thirty (30) days as required by section 38(6) of the Act. Where a Vendor receives a data subject request directly and NexGenius is the Controller for that processing, the Vendor's Data Processing Agreement requires it to forward the request to NexGenius promptly, without responding, unless legally required to respond.

14. Developer, Vendors and Sub-Processors

NexGenius shall not engage any Developer, Vendor, Merchant, Property Partner or other third party to process personal data on its behalf unless a written Data Processing Agreement, in the Company's standard form or containing substantially equivalent terms, is in place. Each such agreement shall require the counterparty to:

- process personal data only on the Company's documented instructions and only to the extent necessary to perform its obligations;
- ensure that its personnel with access to personal data are bound by confidentiality;
- implement appropriate technical and organisational security measures appropriate to the risk;
- assist NexGenius in responding to data subject requests and in complying with its own obligations on security, breach notification and data protection impact assessments;
- register as a data processor with the ODPC where required under section 18 of the Act, and maintain that registration;

- not engage a sub-processor without the Company's prior written or general authorisation, and, where a sub-processor is engaged, impose equivalent data protection obligations on it by written contract;
- notify NexGenius of any personal data breach without undue delay and, in any event, within twenty-four (24) hours of becoming aware of it; and
- on termination or expiry of the relevant agreement, return or securely delete all personal data processed on the Company's behalf, and certify such deletion, save where retention is required by law.

Where a Merchant or Property Partner instead determines the purposes and means of processing certain data it receives via the Platform (for example, End-User contact data received for order fulfilment, or guest data shared by a Property Partner), that counterparty acts as Controller for that specific processing and NexGenius as Processor, as identified in the relevant Data Processing Agreement.

15. Cross-Border Data Transfers

NexGenius shall not transfer personal data outside Kenya, and shall not permit its Developer or any Vendor to do so, save in accordance with sections 48 to 50 of the Act. Before any such transfer, the DPO shall be informed of the destination country and the safeguard relied upon (for example, standard contractual clauses, proof furnished to the ODPC of appropriate safeguards, or another permitted mechanism). Sensitive personal data shall not be transferred outside Kenya unless the data subject has given consent to the transfer and the appropriate safeguards required under section 49(1) of the Act have been confirmed. Common scenarios requiring this assessment include the use of cloud hosting infrastructure, payment gateway processing, or software development or support services provided from outside Kenya.

16. Data Security Measures

NexGenius shall implement and maintain technical and organisational measures appropriate to the risk, including:

- encryption of personal data in transit (TLS 1.2 or higher) and, where technically feasible, at rest;
- role-based access control restricting access to personal data to personnel and systems that require it;
- logging and monitoring of access to production systems containing personal data;
- regular security testing, vulnerability assessment and penetration testing, and prompt patch management;

- a documented incident response procedure enabling breach notification within the timeframes set out in section 17;
- secure disposal or deletion of personal data and devices at the end of their retention period or useful life; and
- additional access restrictions and, where applicable, field-level encryption or masking for sensitive personal data and any data relating to a child.

17. Personal Data Breach Management

Any employee, contractor, Developer or Vendor who becomes aware of an actual or suspected personal data breach must notify the DPO immediately, and in any event within twenty-four (24) hours of becoming aware of it. This internal timeline is deliberately shorter than the forty-eight (48) hour backstop applicable to processors under section 43(3) of the Act, so as to give the Company sufficient time to assess and, where required, notify the ODPC within seventy-two (72) hours of the Company becoming aware of the breach, as required by section 43(1) of the Act.

Where notification to the ODPC is required, it shall describe, to the extent known: the nature of the breach; the categories and approximate number of data subjects and records affected; the likely consequences; the measures taken or proposed to address the breach and mitigate its effects; and the identity and contact details of the DPO, consistent with section 43(5) of the Act. Where the breach is likely to affect the rights and freedoms of data subjects, NexGenius shall also communicate the breach to the affected data subjects without undue delay.

The DPO shall maintain a record of every personal data breach, including the facts relating to the breach, its effects and the remedial action taken, consistent with section 43(8) of the Act. A summary breach-reporting procedure is set out at Annex C.

18. Data Protection Impact Assessments

Where any new product feature, Merchant category, integration or other processing activity is likely to result in a high risk to the rights and freedoms of data subjects within the meaning of section 31 of the Act, for example, large-scale processing of location data, onboarding of a Merchant category that processes health data, or introduction of automated decision-making that affects Riders or Merchants, the relevant business owner shall notify the DPO and a Data Protection Impact Assessment (DPIA) shall be completed before that processing begins. Where a Vendor's processing triggers this threshold, the Vendor's Data Processing Agreement requires it to promptly notify NexGenius and provide the information reasonably required to complete the DPIA.

19. Data Retention and Disposal

Personal data shall not be retained for longer than is reasonably necessary to fulfil the purpose for which it was collected, in accordance with section 39 of the Act, save where retention is required or authorised by law, or is necessary for the establishment, exercise or defence of a legal claim. Illustrative retention periods are set out at Annex B and shall be reviewed periodically by the DPO. On expiry of the applicable retention period, personal data shall be securely deleted, erased, anonymised or pseudonymised. On termination or expiry of a Data Processing Agreement, the relevant Vendor or Developer shall, at the Company's election, return or securely delete all personal data processed on the Company's behalf and certify such deletion.

20. Registration with the Office of the Data Protection Commissioner

NexGenius shall register as a data controller (and, to the extent applicable, data processor) with the ODPC to the extent required under section 18 of the Act, and shall notify the ODPC of any change in the particulars specified under section 19(2) of the Act. The DPO shall maintain the Company's certificate of registration and shall verify, before onboarding, that any Vendor or Developer required to register as a data processor has done so, and shall obtain a copy of that registration certificate on request.

21. Training and Awareness

All employees and contractors with access to personal data shall receive data protection training on induction and periodically thereafter. Training shall cover this Policy, the data subject rights and breach-reporting procedures described above, and role-specific obligations (for example, RBAC discipline for Admin Portal users, or secure handling of payment tokens for finance staff).

22. Complaints Handling

A data subject who is dissatisfied with how NexGenius has processed their personal data may lodge a complaint with the DPO using the contact details at Annex A. The DPO shall acknowledge and investigate the complaint and respond within a reasonable period. If the data subject remains dissatisfied, they may lodge a complaint with the ODPC in accordance with the Data Protection (Complaints Handling and Enforcement Procedures) Regulations, 2021.

23. Monitoring, Audit and Compliance

The DPO shall periodically monitor compliance with this Policy, including by reviewing the Register of Processing Activities, testing breach-response readiness, and auditing Vendors' and the Developer's compliance with their Data Processing Agreements. NexGenius may conduct or commission audits and inspections of any Vendor or

Developor on reasonable prior notice, consistent with the audit rights reserved in the Company's standard-form Data Processing Agreement.

24. Policy Violations and Disciplinary Action

Failure by an employee or contractor to comply with this Policy may result in disciplinary action, up to and including termination, in accordance with the Company's disciplinary procedures. Failure by a Developer or Vendor to comply with its Data Processing Agreement may constitute a material breach of the relevant commercial agreement, entitling NexGenius to the remedies available under that agreement, including termination.

25. Policy Review

This Policy shall be reviewed at least annually, and sooner where triggered by a material change in the Act or Regulations, a significant new processing activity, a personal data breach, or an ODPC direction. The DPO is responsible for proposing amendments to the Board for approval.

Annex A. Data Protection Officer Contact Details

Role	Data Protection Officer, NexGenius Concierge Limited
Name	_____
Email	_____
Telephone	_____
Postal Address	P.O. Box _____, Nairobi, Kenya
ODPC Registration Number	_____

Annex B. Illustrative Data Retention Schedule

The periods below are illustrative and shall be confirmed and maintained by the DPO in the Register of Processing Activities.

Data Category	Illustrative Retention Period	Basis
End-User account and order data	Duration of account, plus 7 years thereafter	Consumer/tax record-keeping requirements
Rider trip-tracking and geolocation data	As necessary for dispute resolution and safety, then anonymised or deleted	Operational necessity; data minimisation
Payment tokens	Per applicable PSP/mobile money operator retention rules	PSP/mobile money operator security standards
Merchant/Property Partner commercial records	Duration of commercial relationship, plus 7 years thereafter	Tax and contractual record-keeping requirements
Personal data breach records	Minimum 5 years from the date of the breach	Section 43(8) of the Act; accountability
Employee/contractor records	Duration of engagement, plus statutory period thereafter	Employment/labour law requirements

Annex C. Personal Data Breach Reporting Procedure

C.1 Any person who becomes aware of an actual or suspected personal data breach notifies the DPO immediately, and in any event within 24 hours, using the contact details at Annex A.

C.2 The DPO records the report and convenes an initial assessment (with IT/security and, where relevant, the Developer or affected Vendor) to establish the nature, scope and cause of the breach.

C.3 The DPO determines whether the breach is likely to result in a risk to the rights and freedoms of data subjects and, if so, prepares a notification to the ODPC for submission within 72 hours of the Company becoming aware of the breach, in accordance with section 43(1) of the Act.

C.4 Where required, the DPO arranges communication to affected data subjects without undue delay, describing the breach and the steps they can take to protect themselves.

C.5 The DPO records the breach, its effects and the remedial action taken in the Company's breach register, in accordance with section 43(8) of the Act, and reports the incident and lessons learned to the Board.

Annex D. Register of Processing Activities — Template Fields

Register Field
Name and contact details of the controller/processor and, where applicable, the DPO
Purpose(s) of the processing
Categories of data subjects and categories of personal data
Categories of recipients to whom personal data has been or will be disclosed (including Vendors and the Developer)
Lawful basis relied upon
Whether the processing involves sensitive personal data or children's data, and the ground relied upon
Details of any cross-border transfer, the destination country and the safeguard relied upon
Retention period applied and the criteria used to determine it
General description of the technical and organisational security measures applied